



WEBSITE SECURITY · PROTECTION REPORT

# How the site is protected, and **what only you can secure**

What was already in place, what we have added, how each protection was tested, and the handful of steps that sit with your own accounts.

**Dear Sir,**

This document follows our build progress report (FN-CFM-002) and covers the security of the Cash Flow Mastery website. Before adding anything, we audited what the site already did, so that the work below targets real gaps rather than a generic checklist.

Every protection listed as tested was checked against the running site, not assumed from the code. Where something could not be tested yet — usually because it depends on your Stripe account being connected — we say so plainly.

The short version: the website itself is now well protected. The remaining risk sits in accounts only you control — the database that will hold customer details, your Stripe settings, and sign-in security on the services the site runs on.

## Security at a glance

Twenty-five protections reviewed. Nothing is blocked on our side.



■ ALREADY IN PLACE ■ ADDED IN THIS ROUND ■ NEEDS YOUR ACTION

**8**

ALREADY IN PLACE, VERIFIED

**11**

ADDED IN THIS ROUND

**6**

NEED ACTION FROM YOU

These were built in from the start. We re-checked each one during the security audit rather than relying on the original build notes.

A1

IN PLACE

**Encrypted connection with strict HTTPS**

Every page is served over HTTPS, and browsers are instructed never to connect to the site any other way for two years.

A2

IN PLACE

**Payment confirmation cannot be faked**

A place on the course is granted only when Stripe itself confirms a payment, and only once the money is marked as paid. Messages claiming to be from Stripe are rejected unless they carry Stripe's signature, and a repeated confirmation can never book a second seat.

A3

IN PLACE

**Prices are set by the server**

The price is calculated on our side from the number of places sold. A visitor cannot edit the amount in their browser to pay less.

A4

IN PLACE

**No secret keys exposed**

Stripe's secret key and the stored customer details are excluded from the code repository. Only Stripe's publishable key, which is designed to be public, is visible in the site.

A5

IN PLACE

**No known vulnerable software**

An automated audit of every third-party package the site uses found **zero known vulnerabilities**.

A6

IN PLACE

**Safe links to outside websites**

All nine links that open another site in a new tab, such as WhatsApp and LinkedIn, are set so that site cannot take control of this one.

A7

IN PLACE

### Forms and checkout accept only what they expect

The form and checkout endpoints reject every request type except the one they use, validate email addresses, and limit the length of names and company names.

A8

IN PLACE

### The confirmation page cannot grant access

The page shown after paying only reports what Stripe says. Opening it without paying shows an error, never a place on the course.

## 02 Added in this round

11 protections

Each of these closes a gap found in the audit. The right-hand column records how it was tested, and the result.

### NEW PROTECTIONS AND HOW EACH WAS VERIFIED

| REF | PROTECTION                                                                                                                                                                                                                                    | TESTED                                                            |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
| S1  | <b>Branded “page not found” page</b><br>A mistyped or old link now shows the site’s own design and navigation instead of a bare default page.                                                                                                 | Returns the correct 404 status with the branded page              |
| S2  | <b>Branded error pages</b><br>If a page fails, visitors see a calm message and a way back. Technical detail is never shown — only a short reference code for support.                                                                         | Built and checked; no live failure to trigger                     |
| S3  | <b>Security headers on every page</b><br>Blocks other sites from embedding this one to trick clicks, limits which sources may run code, stops the payment reference leaking to other sites, and switches off camera, microphone and location. | All present; zero blocked resources across 6 pages                |
| S4  | <b>Limit on repeated submissions</b><br>Each visitor may send 8 form submissions and start 10 checkouts per 10 minutes, so no one can flood the lead list or create endless payment sessions.                                                 | Request 9 refused, with a “try again later” message               |
| S5  | <b>Spam protection on all three forms</b><br>A hidden trap field that only bots fill in, plus a check that rejects forms sent faster than a person could type. No third-party service or puzzle for visitors.                                 | Bot-style submissions stored nothing; a real submission succeeded |

| REF | PROTECTION                                                                                                                                                                                              | TESTED                                                  |
|-----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| S6  | <b>Size limit on incoming requests</b><br>Oversized requests are refused immediately instead of being read in full, which protects against attempts to overload the site.                               | A 20 KB request refused, however it was sent            |
| S7  | <b>Requests must come from this site</b><br>Forms and checkout refuse submissions started from another website.                                                                                         | A request from another website refused                  |
| S8  | <b>Security contact file</b><br>The recognised standard file telling security researchers how to report a problem to you privately.                                                                     | Published in the standard location and reachable        |
| S9  | <b>Hardened search-result data</b><br>The FAQ information given to search engines is written so its text can never be turned into code, which matters if FAQs are ever edited through a content system. | Output checked: safe and still valid for search engines |
| S10 | <b>A full refund withdraws the place</b><br>When a payment is fully refunded, the place is withdrawn and returned to the cohort. A partial refund, such as a goodwill discount, keeps the place.        | Built; needs your Stripe test account to confirm        |
| S11 | <b>Stricter email check at checkout</b><br>An email address passed to checkout must now be genuinely valid, rather than simply containing an “@”.                                                       | Built; needs your Stripe keys to test live              |

## Two limits we want you to know about

**The submission limit (S4) slows abuse rather than stopping it outright.** The site runs on many small servers at once, and each keeps its own count. A determined attacker spreading requests across them can exceed the limit. A firm limit needs a shared service — see item N2 below.

**The code-source rule (S3) keeps the site fast.** The strictest version forces every page to be rebuilt on each visit, making the site slower and costlier to run. We chose a version that keeps pages pre-built while still blocking embedding, foreign form submissions and unexpected code sources.

## 03 What we need from you

6 items

These cannot be done in code, because each depends on an account or a decision that belongs to you. Items N1 to N3 should be settled before the site takes its first real payment.

## A proper database for customer details

Enquiries and enrolments are currently written to a simple file. That is fine for testing, but it is not suitable for personal data, and the live hosting does not keep files permanently — so on the live site, form submissions will not be saved at all. **We recommend Supabase**, which has a free tier. Please create an account, or approve us to set one up in your name.

## A firm limit on repeated submissions

To make the submission limit hold across every server, either upgrade the hosting to **Vercel Pro**, which includes firewall rules, or create a free **Upstash** account. We have built the site so either can be connected in minutes.

## Stripe account settings

Three things in your Stripe dashboard: create a **restricted API key** limited to what the site needs, instead of the all-powerful secret key; switch on **Radar** fraud rules; and share test-mode keys so we can confirm the refund protection (S10) and checkout checks (S11) end to end.

## Two-step sign-in on every account

Please turn on two-factor authentication for Vercel, Stripe, your domain registrar and the email account used for the site. A stolen password on any of these would bypass every protection above.

## Protect your email domain from impersonation

Without SPF, DKIM and DMARC records, anyone can send email that appears to come from `@independentadvisors.ai` — for example, a fake payment request to a prospective student. These are set in your domain's DNS by whoever manages it. We are happy to provide the exact records.

## Confirm the security contact

The security contact file currently lists `carl@independentadvisors.ai` and the domain `cashflowmastery.co`. Please confirm the address reports should go to, and the final domain for the course site.

WHAT TO DO, AND WHO DOES IT

| STEP | ACTION                                                                                                                | WHO                   |
|------|-----------------------------------------------------------------------------------------------------------------------|-----------------------|
| 1    | <b>Turn on two-step sign-in (N4)</b><br>Ten minutes, and it protects everything else.                                 | You                   |
| 2    | <b>Create the database and firewall accounts (N1, N2)</b><br>Or approve us to create them in your name.               | You, then<br>Flarenet |
| 3    | <b>Connect storage and the firm limit</b><br>We move customer data into the database and switch the limit over.       | Flarenet              |
| 4    | <b>Stripe restricted key, Radar and test keys (N3)</b><br>We then run a full test payment and a test refund.          | You, then<br>Flarenet |
| 5    | <b>Email domain records (N5)</b><br>We supply the records; your DNS manager adds them.                                | Flarenet, then<br>you |
| 6    | <b>Confirm contact and domain (N6), then go live</b><br>We update the contact file and remove the preview protection. | You, then<br>Flarenet |

Sir, the website is in a strong position. What remains is mostly a matter of a few settings in accounts only you can reach, and most take minutes. We would be glad to walk through them with you on a short call, or to speak directly with whoever manages your domain.

Flarenet Company

WEB & SOFTWARE DEVELOPMENT